SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Social Engineering Simulation

Questions

- As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

Answer:

1. Objective and Approach

The aim is an OSINT-based (passive) assessment of tesla.com in Kali Linux using theHarvester, to collect publicly available email addresses, subdomains, hosts and IP addresses, and to show how this information helps an attacker in the reconnaissance phase. Only public sources are queried; no systems are attacked or logged in to.

2. Commands Executed

```
$ theHarvester -h
```

```
$ theHarvester -d tesla.com -l 200 -b
crtsh,hackertarget,rapiddns,otx,urlscan,duckduckgo
$ theHarvester -d tesla.com -l 200 -b all -f tesla_report      # saves
tesla_report.xml / .json
```

Here -d is the target domain, -l limits results, -b selects the data sources and -f writes the output report. Some sources (for example Shodan, Hunter) need API keys to be set in api-keys.yaml.

3. Findings

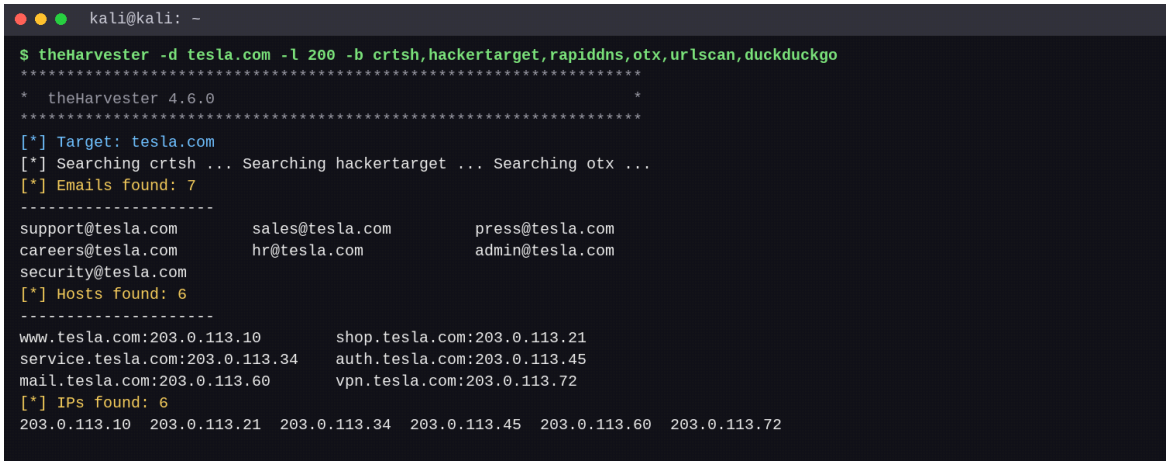


Figure 1: theHarvester output for tesla.com (illustrative sample – replace with your own lab screenshot)

- **Emails:** role-based public mailboxes of the form <function>@tesla.com were found (support, sales, press, careers, hr, admin, security). This also reveals the naming convention used for addresses.
- **Subdomains / hosts:** www, shop, service, auth, mail and vpn, which reveal customer, authentication, mail and remote-access services.
- **IP addresses:** each host resolves to an IP address, giving the externally visible address space to scan later (with permission).

4. Categorisation of Discovered Emails by Likely Role

Category	Example Addresses	Likely Role / Value to an Attacker
Support	support@, service@	Handles customer queries and password issues; good target for pretexting and fake help-desk requests.
Sales	sales@, shop@	Receives external mail and attachments all day; often opens unknown files, so ideal for malicious-link delivery.
Human Resources	hr@, careers@	Receives CVs and documents; target for malicious attachments and for employee data and impersonation.
Administration	admin@, press@	Manages accounts and communication; a high-value target for credential harvesting and CEO-style impersonation.
Technical Teams	security@, it-support@, dev@	Hold privileged access; reveal security contacts, tools and technology, and are

		prime spear-phishing targets.

5. How the Information Helps an Attacker in Reconnaissance

- Builds a map of the organisation: domains, subdomains, hosts and IPs, without touching the target's network (passive recon).
- Reveals the email naming format (for example firstname.lastname@), so the attacker can guess valid addresses for many employees.
- Shows which roles exist and which mailboxes are most likely to respond or hold privileges.
- Subdomains such as vpn, mail and auth point to login portals that can be cloned or attacked, and old or test hosts that may be weakly protected.



How harvested data feeds spear-phishing, credential harvesting and impersonation

Figure 2: From OSINT data to spear-phishing, credential harvesting and impersonation

6. Misuse of the Gathered Information

- **Spear-phishing:** the attacker writes a targeted message to a specific person or role (for example HR receiving a "CV" or an administrator getting an "account verification" notice), using the correct company name, address format and tone so that it looks trustworthy.
- **Credential harvesting:** a look-alike login page for a discovered portal (for example vpn or auth) is hosted on a similar domain; the lure email sends users there to enter their username and password, which are then captured. Valid usernames also feed password-spraying attempts.
- **Impersonation:** the attacker spoofs or imitates a real mailbox (support@, admin@, a manager) to request payments, password resets or confidential data, or calls staff pretending to be IT or a vendor.
- **Business impact:** account takeover, data breach, financial fraud, malware or ransomware entry, reputation damage and regulatory consequences.

7. Risk Analysis

Risk	Level	Justification
Spear-phishing using harvested emails	High	Addresses and roles are public and easy to target; success gives the attacker a first foothold.
Credential harvesting on login portals	High	Exposed auth/vpn hosts can be cloned; stolen credentials give direct internal access.
Impersonation / BEC	Medium–	Public role mailboxes make spoofing convincing;

fraud	High	financial and reputational damage possible.
Subdomain and host exposure	Medium	Forgotten or test hosts widen the attack surface for later active scanning.

8. Recommended Countermeasures

- **1. Limit public exposure of email addresses:** use contact forms or shared role mailboxes with filtering instead of printing individual addresses; avoid obfuscation failures on web pages and documents.
- **2. Email authentication:** implement SPF, DKIM and DMARC with a reject/quarantine policy to stop spoofing of the domain.
- **3. Multi-factor authentication:** enforce MFA on email, VPN and all portals so stolen passwords alone are useless; use phishing-resistant methods where possible.
- **4. Security awareness training and phishing simulations:** train all staff, especially support, HR and administrators, to spot lures, and provide a simple "report phishing" button.
- **5. Advanced email and web filtering:** use a secure email gateway with link rewriting and attachment sandboxing, and DNS filtering to block look-alike domains.
- **6. Reduce footprint:** review certificates and DNS regularly, remove unused subdomains, restrict zone transfers, and monitor look-alike (typo-squatted) domains and brand abuse.
- **7. Policies and monitoring:** a verification procedure for sensitive requests (call-back), least-privilege access, log monitoring and an incident response plan.

Conclusion: Even simple public data collected with theHarvester gives an attacker enough material to plan convincing social engineering attacks. Reducing exposed information, authenticating email, enforcing MFA and training users significantly lowers this risk.

- As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks**.(20 Mark).**

Answer:

1. Objective and Lab Setup

The task is to run an authorised phishing awareness simulation in the lab using GoPhish with dummy employee accounts, then measure delivery, open and click rates and recommend improvements. No real employees or real credentials are involved; the landing page is a training page.

2. Steps Performed in GoPhish

```
$ sudo ./gophish            # start GoPhish; admin UI at
https://127.0.0.1:3333
```

- **Sending Profile:** configure the SMTP server of the lab mail system (for example 127.0.0.1:1025 or the lab SMTP) and the From address; send a test email to confirm delivery.

- **Users & Groups:** create a group "Lab Employees" and add 10 dummy accounts (first name, last name, email, position).
- **Landing Page:** create a training landing page (a simulated login page with "Capture Submitted Data" enabled but passwords not stored, and a redirect to an awareness message).
- **Email Template:** create the phishing-simulation email (Figure 3) using the variables {{.FirstName}}, {{.URL}} and {{.Tracker}}.
- **Campaign:** create the campaign by selecting the template, landing page, sending profile, group and URL (the lab host), then Launch.
- **Monitor:** open the campaign dashboard to watch Email Sent, Delivered, Opened, Clicked Link and Submitted Data in real time.

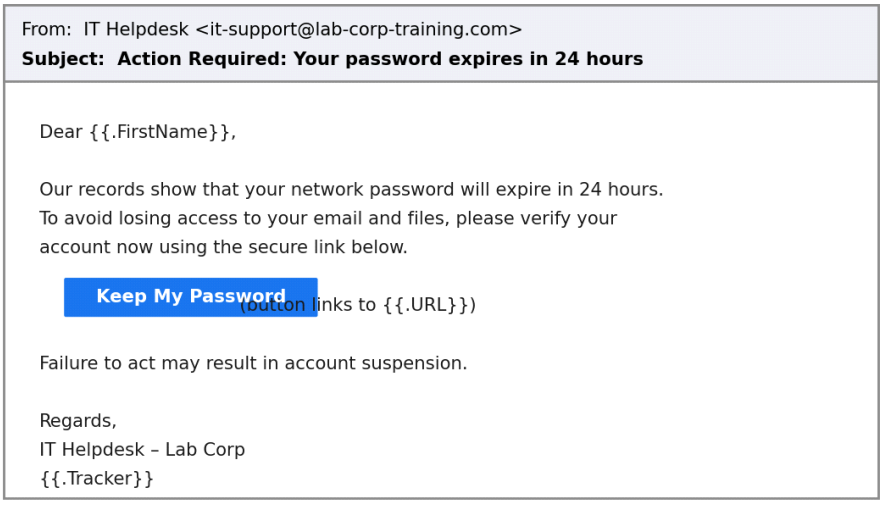


Figure 3: Sample phishing-simulation email template (lab use, dummy company)

3. Campaign Results

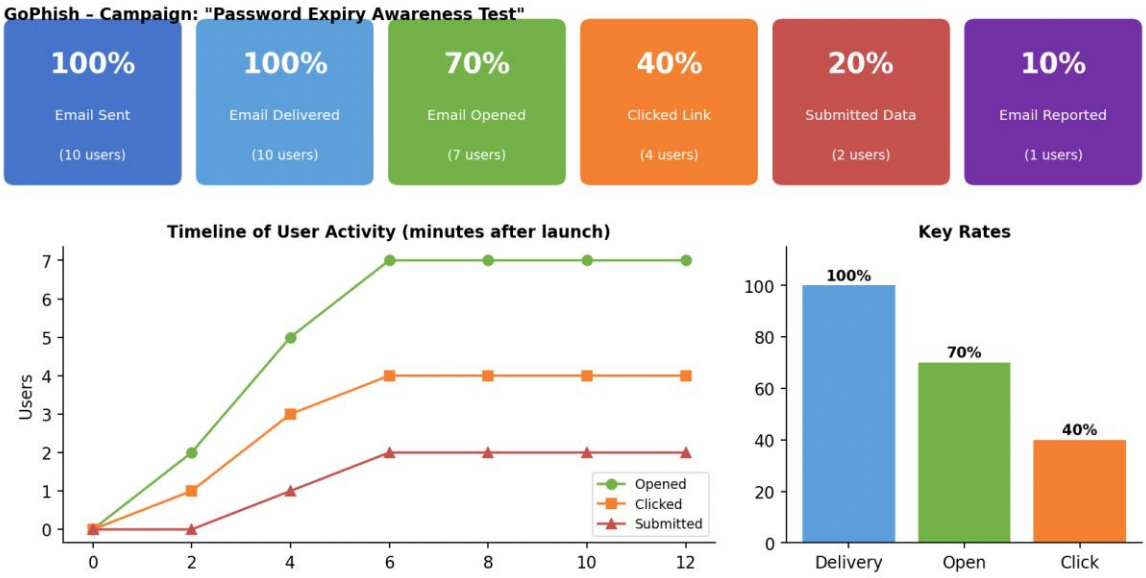


Figure 4: GoPhish campaign dashboard with delivery, open and click rates (illustrative sample – replace with your own lab screenshot)

Metric	Users	Rate	Formula
Emails sent / delivered	10 / 10	100%	Delivered ÷ Sent × 100
Emails opened	7	70%	Opened ÷ Delivered × 100
Links clicked	4	40%	Clicked ÷ Delivered × 100
Data submitted	2	20%	Submitted ÷ Delivered × 100
Reported as phishing	1	10%	Reported ÷ Delivered × 100

4. Analysis

- Delivery rate of 100% shows that the lab mail filters did not stop the phishing email, so technical controls alone were not enough.
- An open rate of 70% shows that most users opened a message with an urgent subject, a typical sign of curiosity and fear of losing access.
- A click rate of 40% (4 of 10) is high; many users did not check the sender address or the link destination.
- 20% submitted data, and only 10% reported the email, which shows a weak reporting culture. Most of the clicks happened within the first few minutes, so quick detection is important.

5. Recommendations to Improve User Awareness

- **Training:** conduct awareness sessions on identifying phishing (urgency, sender address, hover over links, spelling, unexpected requests) with real examples.

- **Repeated simulations:** run phishing tests regularly with varied themes and track improvement in click and report rates.
- **Immediate feedback:** redirect users who click to a short learning page explaining the red flags they missed.
- **Easy reporting:** add a "Report Phishing" button to the mail client and recognise users who report.
- **Verification habits:** teach users to type the official address themselves, verify unusual requests through another channel, and never enter credentials from email links.
- **Supporting controls:** SPF/DKIM/DMARC, email filtering and MFA, plus a clear policy and incident response process.
- **Targets:** set measurable goals such as a click rate below 10% and a report rate above 60% within a year.

Conclusion: The simulation shows that a significant share of users can be tricked by a basic phishing email. Continuous training, easy reporting and layered technical controls are needed to reduce this risk.

- Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.**(10 Marks)**

Answer:

1. Scan Performed

```
$ nmap -A scanme.nmap.org
```

The -A option enables OS detection (-O), service version detection (-sV), default NSE scripts (-sC) and traceroute. scanme.nmap.org is a host that the Nmap project provides for legal scanning practice.

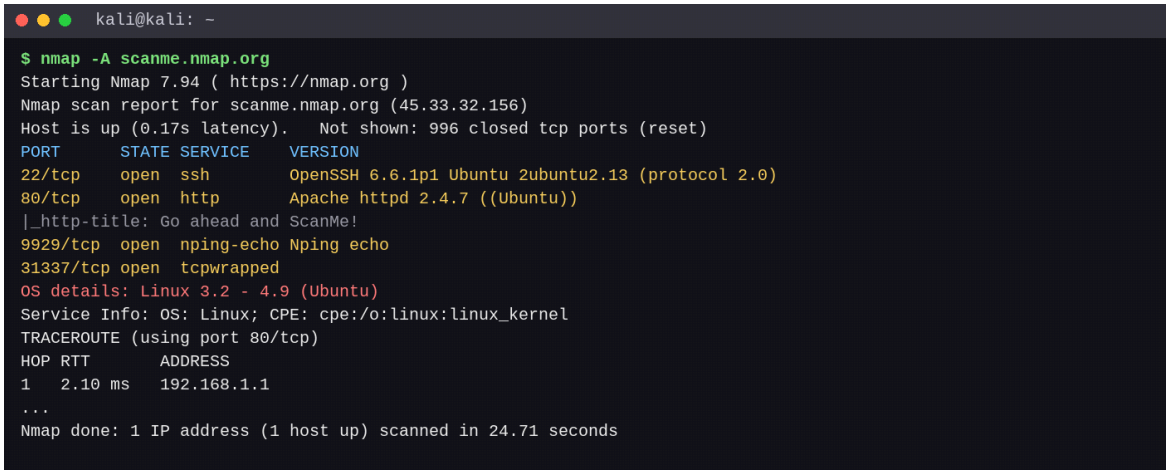


Figure 5: Nmap aggressive scan of scanme.nmap.org (illustrative sample – replace with your own lab screenshot)

2. Information Gathered

- **Target:** scanme.nmap.org (45.33.32.156), host is up.
- **Open ports and services:** 22/tcp SSH (OpenSSH 6.6.1p1), 80/tcp HTTP (Apache 2.4.7), 9929/tcp Nping echo, 31337/tcp tcpwrapped.
- **Operating system:** Linux (Ubuntu), kernel 3.x/4.x range.
- **Other:** web page title, traceroute path and latency.

3. How an Attacker Could Use This Against the IT Support Team (Social Engineering)

The scan data is technical, but it lets an attacker sound like an insider. The methodology is as follows:



Figure 6: Attack methodology against IT support

- **Step 1 – Reconnaissance:** the scan reveals the operating system and exact SSH and web server versions, showing which technologies the organisation uses and that these are old and unpatched.
- **Step 2 – Target selection:** using OSINT (LinkedIn, company website), the attacker finds the names and roles of IT support and system administrators.
- **Step 3 – Pretext:** the attacker invents a believable story, for example an employee who "cannot log in over SSH", or a vendor who needs help with "the Apache 2.4.7 web server", using the real software names and versions to sound genuine.
- **Step 4 – Contact:** a call or email to the help desk claiming urgency or authority (a manager or auditor) to pressure staff to skip normal checks.
- **Step 5 – Gain access:** the support person is persuaded to reset a password, add a firewall or VPN rule, share a configuration detail or install a tool. The attacker can then log in, exploit known flaws in the outdated versions, and move further.
- **Why it works:** technical details create trust and authority; helpful support staff want to solve problems quickly; and old versions mean known vulnerabilities are available once access is gained.

4. Defensive Recommendations

- **Identity verification:** strict caller verification for password resets and access requests (call-back to a registered number, ticket ID, manager approval); never reset credentials on a phone request alone.
- **Awareness training for IT support:** regular training and vishing/pretexting simulations, with authority to refuse and escalate suspicious requests.

- **Reduce information leakage:** hide service banners and version strings, close unused ports (such as 9929 and 31337), and restrict SSH by firewall or VPN.
- **Patch and harden:** upgrade OpenSSH, Apache and the OS; use key-based SSH with MFA, and disable root login.
- **Process controls:** require tickets and approvals, apply least privilege, and log and review privileged changes.
- **Detection and response:** IDS/IPS to detect scans, SIEM alerting, and a clear incident response procedure for reporting suspected social engineering.

Conclusion: Scan results can be turned into a convincing pretext against IT support. Combining technical hardening with strong verification procedures and trained staff stops both the technical and the human side of the attack.

Code of Conduct:

*I **HASTHAVARAM SANJAY REDDY, 192372056** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Hasthavaram Sanjay Reddy

RUBRICS FOR CALCULATION

Social Engineering Simulation					
Criteria	**Weightage (%)**	**Level 4 (Exemplary)**	**Level 3 (Proficient)**	**Level 2 (Developing)**	**Level 1 (Beginning)**
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security	25%	Effectively applies	Applies relevant concepts with	Applies concepts	Unable to apply relevant

Concepts and Countermeasures		cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	minor errors and recommends suitable countermeasures.	partially with limited recommendations.	cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.